

Recuperación Aumentada por Generación para la Evaluación de Impacto relativa a la Protección de Datos Personales: Avance de un Agente de Auditoría de Privacidad

Dylan Antonio Zúñiga Huarca, Jeferson Joao Basurco Casani, Adrian Issac Mamani Quispe
Escuela Profesional de Ingeniería de Sistemas
Universidad Nacional de San Agustín de Arequipa, Arequipa, Perú

Resumen—La Evaluación de Impacto relativa a la Protección de Datos (EIPD o PIA) obliga al auditor a contrastar un tratamiento con normas extensas y heterogéneas. En el Perú, el nuevo Reglamento de la Ley N.º 29733 (D.S. 016-2024-JUS) la incorpora como mecanismo de responsabilidad proactiva. Este artículo presenta el primer avance de un agente inteligente de apoyo a la EIPD: un sistema de Recuperación Aumentada por Generación (RAG) construido sobre un corpus de seis documentos normativos y metodológicos (LPDP, RLPDP, RGPD, WP248, guía de la AEPD y NIST Privacy Framework). Ese corpus suma 390 páginas y 1421 fragmentos. El sistema fragmenta el texto respetando la estructura de artículos y conserva metadatos de fuente, artículo, página y jurisdicción. Indexa los fragmentos con `gemma-embedding-001` en ChromaDB, recupera con *Maximal Marginal Relevance* (MMR) y genera respuestas citadas con `gemma-2.5-flash` bajo un prompt de fundamentación estricta. Sobre un conjunto de 16 preguntas de referencia, la recuperación MMR alcanza $\text{Hit}@6 = 1,000$ y $\text{MRR} = 1,000$, y el 100 % de las respuestas generadas incluye citas verificables. Los resultados respaldan el uso del RAG como herramienta de consulta normativa del agente completo, que se presentará en la tercera unidad.

Index Terms—Evaluación de impacto de privacidad, protección de datos personales, RAG, modelos de lenguaje, auditoría de sistemas, Ley 29733.

I. INTRODUCCIÓN

El tratamiento masivo de datos personales en servicios digitales, sistemas de inteligencia artificial y plataformas de gobierno electrónico aumenta los riesgos para los derechos de las personas. La Evaluación de Impacto relativa a la Protección de Datos (EIPD), conocida internacionalmente como *Privacy Impact Assessment* (PIA), es el instrumento que permite identificar y mitigar esos riesgos *antes* de iniciar el tratamiento [1], [2].

En la Unión Europea, el artículo 35 del RGPD vuelve obligatoria la EIPD cuando es probable que un tratamiento entrañe un alto riesgo [3]. En el Perú, el Reglamento de la Ley N.º 29733 aprobado por D.S. N.º 016-2024-JUS la define como un mecanismo de responsabilidad proactiva. Su artículo 40 la establece como facultativa y recomendada para datos sensibles, perfilamiento, personas vulnerables o grandes volúmenes, y permite elaborarla tomando como referencia la NTP-ISO/IEC 27005 y la NTP-ISO 31000 [4]; en el plano internacional, su

proceso está estandarizado en la ISO/IEC 29134 [5]. Además, el artículo 125 del mismo reglamento considera atenuante de la sanción haberla implementado.

Realizar una EIPD exige que el auditor consulte y relacione varias fuentes: la ley nacional, su reglamento, el derecho comparado y guías metodológicas. Este trabajo es lento y propenso a omisiones. Los modelos de lenguaje de gran tamaño (LLM) pueden asistir en él, pero generan afirmaciones no fundamentadas (“alucinaciones”), un riesgo documentado incluso en herramientas legales comerciales [6]. La técnica RAG mitiga ese problema al condicionar la generación a fragmentos recuperados de un corpus verificable [7], [8].

El Trabajo de Investigación Formativa (TIF) propone un *agente de evaluación de impacto de privacidad*. Este avance entrega su componente de conocimiento: un RAG normativo que responde con citas a fuente, artículo y página. Sus contribuciones son:

- un corpus curado y trazable sobre la EIPD, centrado en el marco peruano y complementado con referencias internacionales;
- un pipeline de fragmentación consciente de la estructura de artículos, con metadatos que permiten citar con precisión;
- una evaluación cuantitativa de la recuperación que compara búsqueda por similitud y MMR, más un análisis de las respuestas generadas.

II. MARCO TEÓRICO

II-A. Evaluación de impacto relativa a la protección de datos

La EIPD es un proceso sistemático con cuatro partes: describir el tratamiento, evaluar su necesidad y proporcionalidad, identificar y valorar los riesgos para los derechos y libertades, y definir las medidas para afrontarlos [3], [9]. Las directrices WP248 proponen nueve criterios de alto riesgo, entre ellos la evaluación o el perfilamiento, las decisiones automatizadas, la observación sistemática, los datos sensibles y el tratamiento a gran escala. Como regla práctica, un tratamiento que cumple dos o más criterios suele requerir una EIPD [9]. La guía de la AEPD integra la EIPD en la gestión del riesgo y estima

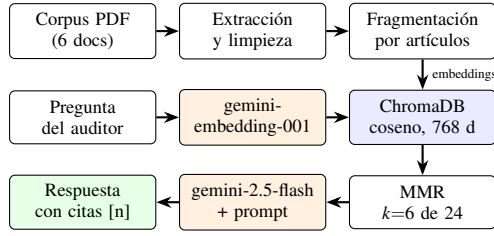


Figura 1. Arquitectura del RAG normativo. Arriba, la ingesta fuera de línea; abajo, la consulta en línea.

el nivel de riesgo a partir de la probabilidad y el impacto [10]. Por su parte, el NIST Privacy Framework organiza las actividades en las funciones *Identify-P*, *Govern-P*, *Control-P*, *Communicate-P* y *Protect-P* [11].

II-B. Recuperación Aumentada por Generación

RAG combina un recuperador no paramétrico con un generador paramétrico [7]. Dada una consulta q , el recuperador obtiene los k fragmentos $\{d_i\}$ más relevantes de un índice vectorial y el generador produce la respuesta $y \sim p_\theta(y | q, d_1, \dots, d_k)$. La relevancia se mide con la similitud coseno entre los embeddings $\mathbf{e}_q$ y $\mathbf{e}_d$.

II-C. Maximal Marginal Relevance

Los textos normativos contienen muchos fragmentos casi redundantes; por ejemplo, un mismo artículo puede quedar dividido en varios fragmentos. MMR [12] reordena los candidatos para equilibrar relevancia y diversidad:

$$d^* = \arg \max_{d_i \in R \setminus S} \left[\lambda \text{sim}(d_i, q) - (1 - \lambda) \max_{d_j \in S} \text{sim}(d_i, d_j) \right] \quad (1)$$

donde R es el conjunto de candidatos, S el de fragmentos ya seleccionados y $\lambda \in [0, 1]$ controla el equilibrio entre relevancia y diversidad.

III. TRABAJOS RELACIONADOS

Clarke [1] y Wright [2] describen el origen y el estado del arte de las PIA como práctica de gestión del riesgo, y la norma ISO/IEC 29134 [5] estandariza su proceso. En el campo de la IA, Gao *et al.* [8] revisan las variantes de RAG (*naïve*, avanzado y modular) y sus métricas de evaluación. RAGAS [13] propone métricas automáticas de fidelidad y relevancia. Magesh *et al.* [6] muestran que incluso los sistemas legales basados en RAG alucinan con frecuencia, por lo que resulta importante exigir citas verificables y evaluar la recuperación de forma independiente. Nuestro trabajo aplica estas ideas al dominio concreto de la EIPD y a la normativa peruana vigente desde 2025.

IV. DISEÑO DEL SISTEMA

La Fig. 1 resume la arquitectura. La implementación usa Python 3.12, LangChain, ChromaDB y la API de Gemini.

Tabla I
CORPUS INDEXADO

Sigla	Documento (jurisdicción)	Págs.	Frag.
LPDP	Ley N.º 29733 (Perú)	17	63
RLPDP	D.S. N.º 016-2024-JUS (Perú)	60	200
RGPD	Reglamento (UE) 2016/679 (Unión Europea)	88	449
WP248	WP248 rev.01 (Unión Europea)	22	79
AEPD	AEPD (España)	160	486
NIST-PF	NIST Privacy Framework v1.0 (EE. UU.)	43	144
Total		390	1421

IV-A. Corpus

La Tabla I lista los documentos. Se priorizó la normativa peruana vigente (LPDP y el nuevo RLPDP), complementada con la fuente europea de la EIPD (RGPD y WP248) y dos marcos metodológicos de gestión del riesgo (AEPD y NIST). Todos son documentos públicos.

IV-B. Preprocesamiento y fragmentación

El texto se extrae por página con `pypdf` y se normalizan varios artefactos: ligaduras separadas (“modificatoria”), guiones de corte de línea y espacios redundantes. Los fragmentos se generan con un *splitter* recursivo de 1200 caracteres y 200 de solapamiento, cuyos separadores priorizan TÍTULO, CAPÍTULO y Artículo, de modo que los cortes caigan en los límites naturales de la norma. Cada fragmento conserva el desplazamiento de inicio, que sirve para calcular su página. Su artículo se asigna mediante una expresión regular: se toma el primer encabezado que aparece dentro del fragmento o, si no hay ninguno, el último anterior. Esa detección solo se aplica a las normas; en las guías, cadenas como “Article 29 Working Party” generarían falsos positivos. En el RGPD, los fragmentos anteriores al articulado se etiquetan con su *considerando*. Como las notas al pie usan el mismo formato “(1) DO C...”, solo se aceptan los números que siguen la secuencia 1, 2, 3... Así se obtienen citas del tipo “RLPDP, art. 40, p. 24” o “RGPD, cons. 91, p. 17”.

IV-C. Indexación

Los fragmentos se vectorizan con `gemini-embedding-001`, un modelo multilingüe que permite consultar en español documentos en inglés como WP248 y el NIST Privacy Framework. Se usa el tipo de tarea `RETRIEVAL_DOCUMENT` y una dimensión reducida a 768, gracias a su entrenamiento Matryoshka. Los vectores se almacenan en ChromaDB con índice HNSW y distancia coseno. Para respetar los límites del plan gratuito, la ingesta procesa lotes de 50 fragmentos con pausas y reintentos exponenciales.

IV-D. Recuperación y generación

La consulta se vectoriza con el tipo `RETRIEVAL_QUERY`. Se obtienen 24 candidatos, de los que MMR con $\lambda = 0,6$ selecciona 6. De forma opcional, se filtra por jurisdicción a través de los metadatos. Los fragmentos se numeran [1]..[6] con su etiqueta de procedencia y se pasan a `gemini-2.5-flash`.

Tabla II
MÉTRICAS DE RECUPERACIÓN ($k = 6, 16$ PREGUNTAS)

Estrategia	Hit@6	MRR	P@6	Fuentes dist.	Lat. (s)
Similitud	1,000	1,000	0,729	1,938	0,714
MMR ($\lambda=0,6$)	1,000	1,000	0,625	2,188	0,612

($T = 0,1$). El prompt de sistema le exige cuatro cosas: responder solo con el contexto, citar cada afirmación, declarar explícitamente cuando la información sea insuficiente y distinguir la norma peruana vinculante de las referencias comparadas.

IV-E. Protocolo de evaluación

Se construyó un conjunto de 16 preguntas que cubre obligatoriedad, contenido mínimo, criterios de alto riesgo, consulta previa, principios, derechos, seguridad, transferencias y metodologías de riesgo. Cada pregunta tiene anotadas las fuentes, los artículos y, en el RGPD, los considerandos relevantes. Un fragmento recuperado cuenta como relevante si coincide con una fuente esperada y, cuando se especifican artículos o considerandos, también con uno de ellos. Se reportan Hit@ k , Mean Reciprocal Rank (MRR) y Precision@ k para dos estrategias: similitud pura y MMR. Además, se generan respuestas para todas las preguntas y se mide la proporción que contiene citas.

V. RESULTADOS

La Tabla II resume la recuperación. Ambas estrategias recuperan al menos un fragmento relevante en todas las preguntas (Hit@6 de 1,000 con similitud y 1,000 con MMR). MMR eleva la diversidad de fuentes por consulta de 1,938 a 2,188, lo que aporta contexto comparado; ambas estrategias empatan en MRR. La menor P@6 de MMR es esperable: al penalizar la redundancia sustituye fragmentos contiguos del mismo artículo por fragmentos de otras fuentes.

En cuanto a la generación, el 100 % de las respuestas incluye citas numeradas a los fragmentos, y la latencia media de extremo a extremo fue de 8,1 s. En la inspección manual (eval/resultados/respuestas.md), las respuestas distinguen correctamente el carácter facultativo de la EIPD en el Perú frente a su obligatoriedad en el RGPD, y no se observaron artículos inventados. En 3 respuestas el modelo advierte de forma explícita que el corpus no cubre una parte de la pregunta (p. ej., que no existe una lista peruana de criterios de alto riesgo equivalente a WP248). Es el comportamiento esperado del prompt de fundamentación.

La Fig. 2 muestra una respuesta real del sistema a una pregunta central para la EIPD en el Perú.

VI. DISCUSIÓN Y LIMITACIONES

- **Tamaño y construcción del conjunto de evaluación.** Con 16 preguntas, las métricas son indicativas y no concluyentes. El conjunto se refinó entre iteraciones. En la primera versión, los fragmentos de considerandos del RGPD carecían de etiqueta, una guía tenía un falso positivo de artículo y la anotación omitía el art. 25 de la LPDP; con ello, la recuperación obtuvo Hit@6 = 0,938

En Perú, la Evaluación de Impacto relativa a la Protección de Datos Personales (EIPD) es de carácter facultativo [2].
El titular del banco de datos o responsable del tratamiento puede realizarla de manera opcional y previa al tratamiento de datos personales [2].
Se recomienda realizarla especialmente en los siguientes casos [1]:
- Cuando se trate de datos sensibles [1].
- Cuando se utilicen datos con fines de crear perfiles personales [1].
- Cuando se traten datos de personas en especial situación de vulnerabilidad, como niños, niñas y adolescentes, personas pertenecientes a pueblos indígenas en situación de aislamiento y/o contacto inicial, o personas con discapacidad [1].
- Cuando se realice tratamiento de grandes volúmenes de datos [1].
- En otros supuestos determinados por la Autoridad Nacional de Protección de Datos Personales [1].
Para su elaboración, se pueden tomar como referencia la guía, lineamientos y procedimientos establecidos en la NTP-ISO/IEC 27005 y la NTP-ISO 31000 en su edición vigente, u otros estándares relacionados con el análisis y la evaluación de riesgos para la protección de datos personales [1]. La Autoridad Nacional de Protección de Datos Personales emitirá las disposiciones complementarias pertinentes para su realización [1].

Figura 2. Respuesta del RAG (extracto) a “¿Es obligatoria la evaluación de impacto de protección de datos personales en el Perú?”.

y MRR = 0,818 (similitud). Tras corregir la fragmentación y reconocer como relevantes los considerandos que tratan cada tema, las métricas llegan al techo. Por ello, se requiere un conjunto más amplio y anotado de forma independiente, con preguntas más difíciles. Para la versión final se ampliará el conjunto y se añadirán métricas de fidelidad del tipo RAGAS [13].

- **Calidad de extracción.** El corpus incluye documentos en PDF a dos columnas o con tablas (AEPD, NIST), que pierden estructura al extraerse. Una extracción consciente del diseño mejoraría esos fragmentos.
- **Cobertura normativa.** Las normas técnicas ISO/IEC 29134, NTP-ISO/IEC 27005 y NTP-ISO 31000 no se incluyeron porque son documentos con derechos de autor. Las disposiciones complementarias que emita la ANPD sobre la EIPD deberán incorporarse cuando se publiquen.
- **Responsabilidad.** El sistema apoya al auditor, pero no reemplaza su juicio profesional ni constituye asesoría legal.

VII. CONCLUSIONES Y TRABAJO FUTURO

Se implementó y evaluó un RAG normativo especializado en la EIPD. Recupera con precisión los artículos clave, como el art. 35 del RGPD y el art. 40 del RLPDP, y genera respuestas trazables con cita a fuente, artículo y página. La fragmentación consciente de la estructura legal y los metadatos de procedencia resultaron esenciales para esa trazabilidad. En la tercera unidad, este RAG será la herramienta de conocimiento del agente de evaluación de impacto de privacidad. El agente guiará la descripción del tratamiento, aplicará un tamizaje con los criterios de WP248, el art. 35 del RGPD y el art. 40 del

RLPDP, valorará los riesgos según su probabilidad e impacto, propondrá medidas y generará automáticamente el informe de la EIPD.

REFERENCIAS

- [1] R. Clarke, "Privacy impact assessment: Its origins and development," *Computer Law & Security Review*, vol. 25, no. 2, pp. 123–135, 2009.
- [2] D. Wright, "The state of the art in privacy impact assessment," *Computer Law & Security Review*, vol. 28, no. 1, pp. 54–61, 2012.
- [3] Parlamento Europeo y Consejo de la Unión Europea, "Reglamento (UE) 2016/679 relativo a la protección de las personas físicas en lo que respecta al tratamiento de datos personales (RGPD)," Diario Oficial de la Unión Europea, L 119, 2016.
- [4] Ministerio de Justicia y Derechos Humanos, "Decreto supremo n.º 016-2024-jus, reglamento de la ley n.º 29733, ley de protección de datos personales," Diario Oficial El Peruano, 30 nov., 2024.
- [5] ISO/IEC, "ISO/IEC 29134:2017 — information technology — security techniques — guidelines for privacy impact assessment," International Organization for Standardization, 2017.
- [6] V. Magesh, F. Surani, M. Dahl, M. Suzgun, C. D. Manning, and D. E. Ho, "Hallucination-free? Assessing the reliability of leading AI legal research tools," 2024, arXiv:2405.20325.
- [7] P. Lewis, E. Perez, A. Piktus, F. Petroni, V. Karpukhin, N. Goyal, H. Küttler, M. Lewis, W.-t. Yih, T. Rocktäschel, S. Riedel, and D. Kiela, "Retrieval-augmented generation for knowledge-intensive NLP tasks," in *Advances in Neural Information Processing Systems*, vol. 33, 2020, pp. 9459–9474.
- [8] Y. Gao, Y. Xiong, X. Gao, K. Jia, J. Pan, Y. Bi, Y. Dai, J. Sun, M. Wang, and H. Wang, "Retrieval-augmented generation for large language models: A survey," 2023, arXiv:2312.10997.
- [9] Grupo de Trabajo del Artículo 29, "Directrices sobre la evaluación de impacto relativa a la protección de datos (EIPD), WP248 rev.01," Comisión Europea, 2017.
- [10] Agencia Española de Protección de Datos, "Gestión del riesgo y evaluación de impacto en tratamientos de datos personales," AEPD, Madrid, 2021.
- [11] National Institute of Standards and Technology, "NIST privacy framework: A tool for improving privacy through enterprise risk management, version 1.0," NIST, Tech. Rep. CSWP 01162020, 2020.
- [12] J. Carbonell and J. Goldstein, "The use of MMR, diversity-based reranking for reordering documents and producing summaries," in *Proc. 21st Annu. Int. ACM SIGIR Conf. Research and Development in Information Retrieval*, 1998, pp. 335–336.
- [13] S. Es, J. James, L. Espinosa-Anke, and S. Schockaert, "RAGAS: Automated evaluation of retrieval augmented generation," 2023, arXiv:2309.15217.